

LYTA — POLITIQUE_CONFIDENTIALITE

Politique de confidentialité — LYTA

Dernière mise à jour : 9 juin 2026 Version : 1.1

1. Préambule

La présente politique de confidentialité (« Politique ») décrit comment **Optimislink Sàrl** (ci-après « LYTA », « nous » ou « l'éditeur ») collecte, traite, conserve et protège les **données personnelles** des utilisateurs de la plateforme SaaS LYTA accessible via le domaine **lyta.ch** et ses sous-domaines tenants (***.lyta.ch**).

Cette Politique est conforme à :

- la **nouvelle Loi fédérale suisse sur la protection des données (nLPD)**, entrée en vigueur le 1er septembre 2023, et à son ordonnance d'exécution (OPDo) ;
- le **Règlement général sur la protection des données (RGPD)** de l'Union européenne (UE 2016/679), pour les utilisateurs résidant dans l'UE/EEE ;
- les bonnes pratiques sectorielles applicables au courtage en assurance suisse.

En utilisant LYTA, vous reconnaissez avoir lu et compris la présente Politique.

2. Identité et coordonnées du responsable du traitement

Responsable du traitement (au sens de l'art. 5 lit. j nLPD et art. 4 RGPD) :

Optimislink Sàrl Place de la Fontaine 9 1868 Collombey, Suisse IDE : CHE-229.220.256 Inscription RC : canton du Valais, CH-621.4.012.418-8 (3 juin 2024) Représentant légal : Habib Agharbi, fondateur

Contact dédié à la protection des données : Email : **privacy@lyta.ch** ou **dpo@lyta.ch**

LYTA n'a pas l'obligation légale de désigner un Délégué à la protection des données (DPO) au sens de l'art. 10 nLPD, mais s'engage à traiter toute demande dans les délais légaux.

3. Données collectées

3.1 Données fournies directement par l'utilisateur

Lorsque vous créez un compte ou utilisez LYTA, nous collectons :

Compte utilisateur (broker, collaborateur, partenaire, client final) - Nom, prénom, civilité - Adresse email (identifiant de connexion) - Numéro de téléphone (fixe et mobile) - Photo de profil (optionnel) - Mot de passe (stocké uniquement sous forme hashée — bcrypt/argon2, jamais en clair)

Données du cabinet (tenant) - Raison sociale, IDE, IBAN, QR-IBAN, numéro de TVA - Adresse postale, téléphone, email du cabinet - Logo, charte graphique, branding personnalisé

Données des clients gérés par les brokers - État civil complet (nom, prénom, sexe, date de naissance, état civil, nationalité) - Numéro AVS (donnée sensible — voir section 4) - Adresse, ville, NPA, canton, pays - Données financières : IBAN, banque, salaire, commissions, taux de commission - Profession, employeur, permis de séjour - Tags, notes, historique de suivis commerciaux

Contrats et documents assurance - Police d'assurance (numéro, dates, prime, franchise, produits) - PV de conseil, mandats signés, propositions - Documents scannés (PDF, images) déposés par l'utilisateur

Sinistres et réclamations - Description, date, statut, documents annexes

3.2 Données collectées automatiquement

- **Données de connexion** : adresse IP, date/heure de connexion, navigateur, OS, type d'appareil
- **Logs d'audit** : actions effectuées par chaque utilisateur (création, modification, suppression de données)
- **Préférences utilisateur** : langue (fr/de/it/en), thème (clair/sombre)
- **Cookies techniques** : session, CSRF, préférences (voir section 11)

3.3 Données issues d'intégrations tierces (LYTA Tools — opt-in)

Si l'utilisateur connecte volontairement son compte LYTA à un service tiers via OAuth ou clé API, nous pouvons traiter :

- **Google Workspace** : emails Gmail, événements Google Calendar, fichiers Google Drive (en lecture/écriture selon scopes accordés)
- **Microsoft 365** : emails Outlook, événements Calendar, fichiers OneDrive/SharePoint
- **WhatsApp Business** : messages envoyés/reçus, contacts
- **3CX** : journal d'appels, enregistrements (selon configuration locale)
- **Bexio** : contacts, factures, devis
- **Zoom** : liens de réunion, métadonnées

Ces connexions sont **désactivables à tout moment** depuis l'interface LYTA Tools. Les tokens OAuth sont stockés chiffrés (AES-GCM) côté backend Supabase Zurich.

4. Données sensibles

Certaines données traitées par LYTA relèvent de « **données personnelles sensibles** » au sens de l’art. 5 lit. c nLPD :

- **Numéro AVS** (donnée nécessitant un soin particulier en Suisse)
- **Données de santé** (limites de couverture LAMal/LCA, déclarations de santé, sinistres médicaux)
- **Données financières** (IBAN, salaires, situation patrimoniale)

Ces données sont :

1. Stockées **chiffrées au repos** sur Supabase Zurich
 2. Transmises uniquement via **TLS 1.3** (HTTPS)
 3. Accessibles uniquement aux utilisateurs autorisés (RLS Row-Level Security en base + permissions par rôle)
 4. Masquées par défaut pour les rôles non autorisés (ex : numéro AVS masqué pour les agents non managers)
 5. Tracées dans les logs d’audit pour chaque accès en lecture/modification
-

5. Finalités du traitement

Nous traitons vos données personnelles uniquement pour les finalités suivantes :

Finalité	Base légale (nLPD / RGPD)	Durée
Fourniture du Service SaaS LYTA	Exécution du contrat (art. 31 nLPD / 6.1.b RGPD)	Durée du contrat
Authentification et sécurité des comptes	Intérêt légitime (art. 31 nLPD / 6.1.f RGPD)	Durée du contrat
Gestion administrative et facturation (Stripe)	Exécution du contrat + obligation légale	10 ans (obligation comptable CO art. 957a)
Envoi d'emails transactionnels (Resend)	Exécution du contrat	Durée du contrat
Envoi de SMS de vérification (Twilio)	Exécution du contrat + sécurité	30 jours puis purge
Analyse de documents par IA (OpenAI)	Exécution du contrat — usage explicitement demandé	Durée du traitement (non conservé chez OpenAI, voir section 8.3)
Support utilisateur	Intérêt légitime	3 ans après résolution
Conformité légale (anti-blanchiment, FINMA si applicable)	Obligation légale	10 ans
Statistiques d'usage anonymisées	Intérêt légitime	Indéfinie (données agrégées)

Aucun traitement à des fins de **publicité ciblée**, de **profilage commercial automatisé** ou de **revente de données** n'est effectué.

6. Destinataires des données

Vos données sont accessibles aux catégories de destinataires suivants :

6.1 Internes (LYTA / éditeur)

- Personnel technique autorisé (administrateurs système, ingénieurs avec accès supervisé)
- Personnel support utilisateur (sur ticket explicite uniquement, avec traçabilité)

6.2 Tenants (cabinet de courtage qui utilise LYTA)

- Les **administrateurs du tenant** ont accès aux données de leur propre cabinet et de leurs clients

- Les **collaborateurs** voient les clients qui leur sont assignés selon les permissions configurées par l'admin
- LYTA fait office de **sous-traitant** (au sens de l'art. 9 nLPD) du cabinet pour les données de ses clients finaux

6.3 Sous-traitants techniques

Sous-traitant	Localisation principale	Données traitées	Garanties
Supabase Inc.	Zurich, Suisse (AWS eu-central-2)	Toutes données stockées	DPA signé, ISO 27001 (AWS), chiffrement at rest et in transit
Vercel Inc.	UE (CDN)	Aucune donnée personnelle stockée — uniquement frontend	DPA Vercel, SOC 2 Type II
Stripe Inc.	Irlande (siège UE) / États-Unis	Données de paiement (nom, email, carte)	DPA Stripe, certification PCI-DSS Level 1, Standard Contractual Clauses
Twilio Inc.	Irlande / États-Unis	Numéros de téléphone, contenu des SMS	DPA Twilio, SCC, ISO 27001
Resend Inc.	États-Unis	Email destinataire, contenu	DPA Resend, SCC
OpenAI L.L.C.	États-Unis	Contenu envoyé pour analyse IA (scan documents, chat)	DPA OpenAI API, données NON utilisées pour entraîner les modèles (opt-out par défaut sur l'API)
Infomaniak SA	Suisse	Nom de domaine	Hébergeur suisse, ISO 27001, ISO 50001

6.4 Apps tierces connectées par l'utilisateur (LYTA Tools)

Si vous activez Gmail/Outlook/Bexio/etc., vos données transitent vers ces fournisseurs **avec votre consentement explicite**. Vous restez seul responsable de la conformité de ces connexions.

6.5 Autorités

Nous pouvons être tenus de divulguer vos données aux **autorités suisses compétentes** (judiciaires, fiscales, FINMA, autorité cantonale de protection des données) sur réquisition légale uniquement.

7. Transferts internationaux

LYTA s'engage à minimiser les transferts hors de Suisse :

- **Données principales (DB, fichiers, comptes)** : stockées **exclusivement en Suisse** (Supabase Zurich)
- **Sous-traitants situés hors Suisse / UE (Stripe, Twilio, Resend, OpenAI, Vercel)** : transferts encadrés par :
 - les **Clauses Contractuelles Types (SCC)** approuvées par la Commission européenne
 - et/ou les **adequacy decisions** des autorités suisses ou européennes
 - et/ou les **garanties supplémentaires** (chiffrement bout-en-bout, pseudonymisation)

Les pays destinataires (États-Unis, Irlande, Royaume-Uni) bénéficient de cadres juridiques reconnus pour les transferts internationaux (Data Privacy Framework US-CH/UE pour les États-Unis).

8. Sécurité

8.1 Mesures techniques

- **Chiffrement TLS 1.3** pour toutes les communications client [?] serveur
- **Chiffrement at rest** (AES-256) sur la base de données Supabase Zurich
- **Hachage** des mots de passe (bcrypt/argon2) — jamais stockés en clair
- **Chiffrement AES-GCM** des tokens OAuth stockés
- **Row-Level Security (RLS)** PostgreSQL : isolation stricte tenant par tenant — un cabinet ne peut JAMAIS voir les données d'un autre cabinet
- **Authentification multi-facteurs (2FA)** disponible et recommandée pour les admins
- **Vérification SMS** des numéros via Twilio
- **Politiques de mots de passe** : longueur minimale 8 caractères + complexité
- **Sessions JWT** signées et chiffrées, expiration configurable
- **Logs d'audit** : chaque action sensible est tracée (qui, quoi, quand)
- **Backups quotidiens** chiffrés (rétention 7-30 jours selon plan)

8.2 Mesures organisationnelles

- Accès aux données de production limité aux personnes strictement nécessaires
- Politique de moindre privilège (Least Privilege)

- Engagements de confidentialité signés par tous les intervenants
- Procédure de notification de violation dans les 72h aux autorités (art. 24 nLPD / art. 33 RGPD)

8.3 OpenAI / Traitement IA — précisions

Les données envoyées à OpenAI pour analyse (scan de documents, assistant IA) sont : - envoyées **chiffrées via TLS** vers l'API OpenAI - traitées par OpenAI **uniquement le temps de la requête - NON utilisées pour entraîner les modèles** (opt-out par défaut sur l'API entreprise) - conservées par OpenAI **maximum 30 jours** pour la détection d'abus, puis supprimées - soumises au [DPA OpenAI API](#)

L'utilisateur peut **désactiver les fonctionnalités IA** dans les paramètres du tenant.

9. Durée de conservation

Les durées de conservation appliquées sont :

Type de donnée	Durée
Compte utilisateur actif	Durée du contrat + 12 mois
Compte utilisateur supprimé (sur demande)	Suppression sous 30 jours, sauf obligation légale
Données clients d'un broker (cabinet abonné)	Durée du contrat tenant + 12 mois
Données comptables (factures, contrats commerciaux)	10 ans (art. 957a CO)
Logs de connexion	12 mois
Logs d'audit	3 ans
Backups	30 jours (rolling)
Tokens OAuth d'intégrations	Supprimés à la déconnexion volontaire
Données IA (chez OpenAI)	30 jours max (politique OpenAI)

À l'issue de ces durées, les données sont **soit anonymisées de manière irréversible, soit supprimées**.

10. Droits des personnes concernées

Conformément à la nLPD et au RGPD, vous disposez des droits suivants :

Droit	Description	Base légale
Accès	Obtenir confirmation et copie de vos données	art. 25 nLPD / art. 15 RGPD
Rectification	Corriger des données inexactes ou incomplètes	art. 32 nLPD / art. 16 RGPD
Effacement (« droit à l'oubli »)	Demander la suppression définitive	art. 32 nLPD / art. 17 RGPD
Limitation	Restreindre un traitement contesté	art. 18 RGPD
Opposition	S'opposer à un traitement fondé sur l'intérêt légitime	art. 30 nLPD / art. 21 RGPD
Portabilité	Récupérer vos données dans un format structuré (JSON, CSV)	art. 28 nLPD / art. 20 RGPD
Retrait du consentement	À tout moment, sans rétroactivité	art. 7 RGPD
Réclamation	Déposer plainte auprès de l'autorité compétente	art. 49 nLPD / art. 77 RGPD

Comment exercer vos droits ?

Adressez votre demande à : **privacy@lyta.ch**

Nous vous répondrons dans un délai de **30 jours** (prolongeable à 60 jours pour les demandes complexes, avec notification motivée). Une preuve d'identité pourra être demandée pour des raisons de sécurité.

Export complet de vos données : disponible directement via la fonction « Exporter mes données » dans les paramètres du compte (format JSON + ZIP des fichiers).

Suppression de compte : disponible via les paramètres du compte ou sur demande à privacy@lyta.ch.

Autorité de contrôle

- **Suisse** : Préposé fédéral à la protection des données et à la transparence (PFPDT) <https://www.edoeb.admin.ch>
- **UE** : autorité de contrôle de votre pays de résidence (ex : CNIL en France, CNPD au Luxembourg)

11. Cookies

LYTA utilise des cookies strictement nécessaires :

Cookie	Finalité	Durée	Tiers
sb-access-token , sb-refresh-token	Session d'authentification Supabase	Session / 7 jours	Non
csrf-token	Protection contre les attaques CSRF	Session	Non
crm_settings (localStorage)	Préférences UI (thème, langue)	Persistant	Non
welcomeShown (sessionStorage)	Marqueur d'accueil de première connexion	Session	Non

Aucun cookie de tracking publicitaire, de réseaux sociaux, ou d'analytics tiers n'est déposé par défaut.

Si l'utilisateur active des intégrations tierces (LYTA Tools), des cookies des services connectés peuvent être déposés selon leurs propres politiques.

12. Profilage et décisions automatisées

Les fonctionnalités IA de LYTA (SmartFlow, scan documents, assistant) **ne prennent pas de décisions à effets juridiques** sur les personnes concernées. Elles assistent l'utilisateur (broker), qui reste **seul décideur final**.

Aucun scoring de risque, ranking client ou refus automatisé n'est effectué sans intervention humaine.

13. Mineurs

LYTA n'est pas destiné aux mineurs de moins de 16 ans. L'éditeur ne collecte pas sciemment de données personnelles de mineurs. Si un parent ou tuteur découvre qu'un mineur a fourni des informations, il est invité à nous contacter à privacy@lyta.ch pour suppression.

Les données des **clients finaux** (qui peuvent être mineurs si assurés sur un contrat familial) sont saisies sous la responsabilité du cabinet de courtage abonné, qui s'engage à respecter les autorisations parentales.

14. Modifications de la présente Politique

Cette Politique peut être modifiée pour refléter les évolutions techniques, juridiques ou les nouveaux services. Toute modification substantielle sera notifiée :

- par email aux utilisateurs concernés au moins 30 jours avant entrée en vigueur
- via une bannière visible dans l'interface LYTA
- en mettant à jour la date « Dernière mise à jour » en tête de document

L'usage continu du Service après notification vaut acceptation de la nouvelle Politique. À défaut, vous pouvez exercer votre droit de résiliation conformément aux CGU.

15. Contact

Pour toute question, demande d'exercice de droits ou réclamation :

- **Email confidentialité** : privacy@lyta.ch
 - **Email général** : contact@lyta.ch
 - **Adresse postale** : Optimislink Sàrl, Place de la Fontaine 9, 1868 Collombey, Suisse
 - **Téléphone** : +41 78 212 23 60
-

Annexe — Glossaire

- **nLPD** : nouvelle Loi fédérale suisse sur la protection des données (en vigueur depuis le 1er septembre 2023)
- **RGPD** : Règlement général sur la protection des données — UE 2016/679
- **Tenant** : cabinet de courtage abonné à LYTA, disposant de son propre espace isolé
- **DPA** : Data Processing Agreement (Accord de sous-traitance)
- **SCC** : Standard Contractual Clauses (Clauses contractuelles types)
- **RLS** : Row-Level Security (sécurité au niveau de la ligne en base de données)
- **OAuth** : protocole d'autorisation pour connexions tierces sans partage de mot de passe